CampusClaw

个人项目阶段验收报告

多 AI 应用 · Prompt 模板 · Skill 路由 · MCP 工具编排 · 全链路追踪

仓库：https://github.com/NEVERLANDlpx/campusclaw.git

报告日期：2026-10-26（Asia/Shanghai）

实现基线：Flask + SQLite；认证：Bearer JWT；MCP：官方 Python SDK Streamable HTTP

1. 项目概览

CampusClaw 是面向课程班级的知识空间。现有材料上传下载、班级隔离、知识切片、混合检索与 SSE 问答均被保留；本阶段以增量方式补齐应用级 Prompt、受控 Skill、独立 MCP 服务、宿主工具调用循环以及可授权审计。

实现原则

- 所有身份、班级、角色、应用、Skill 与工具授权都由服务端数据库身份决定；客户端 class_id 和 skill_enabled 不参与授权。
- 密码继续使用 bcrypt 哈希；JWT、LLM Key 与 MCP 令牌来自环境变量，日志不记录凭据。
- 上传 Skill 是指令文本，不执行其中的 Python、Shell 或其他代码。
- 数据库迁移采用 CREATE IF NOT EXISTS、受控 ALTER 和幂等种子，不要求删除既有数据库。

交付范围

领域	交付能力
AI 应用	每班四应用、独立 Prompt 与检索参数、模板复制
Skill	三内置 Skill、Markdown 上传、绑定、单 Skill 路由、注入追踪
MCP	官方协议服务、Bearer、发现、Schema、调用循环、限额与审计
追踪	真实 LLM 请求/响应结构、检索命中、Skill 路由、MCP 调用与 SSE

2. 架构与数据流

独立工具服务与宿主编排是两个交付物。Flask 宿主不复制工具 Schema，而是从 MCP tools/list 的发现清单生成 OpenAI function 声明。

请求链路

Bearer 用户 → 查询本班 enabled 应用 → 按应用配置检索 Top-K → 从绑定且启用 Skill 中确定性选一个 → 渲染 system message → 生成当前 Skill 的可用工具声明 → 调用 LLM → 校验 tool_calls → 调用 MCP → 追加 role=tool 消息 → 再次调用 LLM → SSE 输出与审计。

关键数据表

表	用途
assistant_apps / prompt_templates	应用级 Prompt、参数及模板复制
skills / assistant_app_skills / assistant_skill_tools	Skill 定义、应用绑定与工具授权
mcp_servers / mcp_discovered_tools	服务器登记与最近成功发现清单
llm_call_logs / mcp_call_logs / skill_route_logs	模型、工具和路由追踪

安全边界

工具绑定在配置期验证引用格式、班级、连接状态和发现 Schema；运行期再次检查。工具结果以不可信 role=tool 消息进入模型上下文，命中已知提示词注入句式时整段替换为固定安全提示。该过滤明确不是完备防护。

3. 核心功能

四个内置应用

应用	检索	主要行为
通用 AI 对话	关闭	通用回答，不声称查阅班级资料
课程知识库问答	Hybrid	基于真实切片并引用来源
学习辅导助手	Hybrid	命中 solving_guidance 后优先给思路与步骤
课程工具助手	按配置	命中 course_tool_assistant 后仅声明授权 MCP 工具

Prompt 与 Skill

模板只允许 app_name、class_name、knowledge_policy、skill_content 四个变量。应用模板采用复制语义。即使教师自定义 Prompt 没有 skill_content 占位符，服务端仍会把命中的完整 Skill 指令追加到最终 system message，避免界面显示启用但实际未注入。

MCP 服务

服务实现 lookup_course_glossary(term) 与 formula_hint(expression)。公式工具使用受限 AST，只允许数字、括号及基本算术运算；不使用 eval。令牌错误返回 401。

调用限额

默认最多 3 个工具轮次、累计 5 次调用，两个上限可分别配置。达到上限后不再发送 tools，并尝试基于已有工具结果生成降级回答。

4. 验收问题 1-2

问题 1：提示词是否进入模型请求

对同一问题分别运行通用应用和知识库应用。llm_call_logs 中两次 request_json.messages[0] 不同，均包含解析后的应用名与班级名。修改一个应用的 Prompt 后，另一个应用保持原值。请求日志只保存实际发送的 model、messages、temperature、max_tokens、stream；没有发送的 tools 不会虚构写入。

结论：可控 LLM 链路验证通过；真实课程 LLM 网关未运行。

问题 2：是否传递整个知识库

meta 保存 total_chunks、hit_chunk_ids、mode 与 top_k。实际 user message 只包含命中 evidence 的切片 ID、偏移、标题和摘录，不含整库全文。未启用检索的应用返回 mode=disabled；启用检索但无命中时固定返回“资料中未找到相关内容”，不调用 LLM。

示例元数据

{"mode":"hybrid","total_chunks":2,"hit_chunk_ids":[1,2],"top_k":4}

结论：宿主只传递本次选中的 Top-K 证据。

5. 验收问题 3-4

问题 3：Skill 是否完整进入模型请求

学习辅导问题命中 solving_guidance 后，路由日志保存候选、命中关键词、选择原因和完整内容 SHA-256；实际 system message 含 Skill 标识和数据库中的完整指令。禁用、未绑定或未命中时不注入。

问题 4：Skill 执行逻辑

Skill 的执行定义为：应用绑定 → 启用过滤 → 关键词匹配 → 匹配数与优先级排序 → 最多选择一个 → 指令注入 → 可选工具候选集。course_tool_assistant 进一步允许 MCP 工具编排。Markdown 文件中的代码块仍只是指令文本。

测试情形	预期/实际
solving_guidance 命中	完整指令进入 system；保存路由哈希
Skill 禁用或未绑定	不进入 system
两个候选同时命中	按匹配数、绑定优先级、Skill 优先级、ID 稳定选择一个
上传内容含 Python 代码块	保存原文，不执行代码

结论：Skill 是可追踪路由与注入机制，不是任意代码执行器。

6. 验收问题 5：MCP 完整调用链

本机真实启动官方 MCP SDK 服务，完成 initialize、tools/list 和 tools/call。为了稳定验证宿主协议处理，产生 tool_calls 的模型是可控假 LLM。两者在证据中明确区分。

步骤	证据
1. tools/list	发现 lookup_course_glossary 与 formula_hint 的真实描述和 JSON Schema
2. LLM tools	只声明当前 Skill 绑定的 lookup_course_glossary
3. tool_calls	可控 LLM 返回稳定函数名及 {term: MCP}
4. 宿主执行	反向映射至 lookup_course_glossary@course-tools 并校验 Schema
5. MCP 返回	真实 tools/call 返回课程术语解释
6. 后续请求	messages 最后一条为 role=tool，包含来源标记
7. 最终响应	第二轮 assistant 文本；tool_call SSE 先于 delta

MCP 令牌只进入服务端 HTTP Authorization。数据库保存 token_env_key；证据、模型请求、响应和普通日志中均未发现凭据标记。错误令牌实际得到 401。

结论：真实 MCP 工具传输与宿主调用已验证；真实课程模型主动 tool_calls 尚待网关环境补验。

7. 测试结果与质量记录

最终命令

```
python -m pytest -q tests -p no:cacheprovider --basetemp=tmp/pytest-full-final2
```

实际结果：79 passed, 1 skipped in 61.26s。跳过项是当前 Windows 账号不能创建符号链接时的既有边界用例，未写成通过。

回归修复记录

首轮全量回归为 51 failed, 27 passed。原因是新 Prompt 渲染函数的导入名覆盖 Flask render_template，导致登录页渲染失败。改为 render_prompt_template 别名后，既有验收单独结果为 60 passed, 1 skipped，最终全量结果如上。

其他验证

项目	实际结果
OpenSpec strict	Change add-ai-apps-skills-mcp-tracing is valid
docker compose config --quiet	退出码 0
官方 MCP SDK 集成测试	真实握手、发现、调用与错误令牌拒绝
凭据扫描	四份证据未发现 Authorization、Bearer、API Key 或令牌变量值

8. 证据索引与复现

证据	内容
01_应用提示词对照_可控LLM.json	两个应用的实际 request/response 与 system 差异
02_检索切片证据_可控LLM.json	总切片数、命中 ID、Top-K、实际 evidence
03_Skill路由与注入_可控LLM.json	候选、选择原因、注入哈希与 system message
04_MCP完整调用链_真实MCP_可控LLM.json	真实发现/调用、tools、tool_calls、tool message 与最终响应

复现命令

```
python scripts/capture_stage_acceptance.py
python -m pytest -q tests -p no:cacheprovider --basetemp=tmp/pytest-full-final
npx @fission-ai/openspec@1.13.1 validate add-ai-apps-skills-mcp-tracing --strict
```

限制与后续

- 当前环境未配置真实课程 embedding/chat 网关；不能把可控假 LLM 结果当作真实模型结果。
- 本次只验证 Compose 配置解析，没有构建或启动 Docker 容器。
- 本次未采集浏览器截图；页面功能由 Flask API 与前端代码、自动测试覆盖。
- 已知句式过滤不能彻底防御工具结果提示词注入；未来写入或外发工具必须新增人工确认与独立授权。

阶段结论

CampusClaw 已从单一班级 Prompt 和布尔 Skill 开关，升级为应用级 Prompt、可管理 Skill、标准 MCP 工具服务、受限宿主循环与可审计调用链。五项验收问题均有可复现证据；真实外部 LLM 与容器运行的未验证边界已明确保留。